

Project 6: Multi-Layered Email Analysis Report

Email Summary:

- **Subject:** PAYMENT CONFIRMATION!!!!
- **Sender:** Avocado attorney avocadoattorney1@gmail.com
- **Recipient:** onyedikapaulashuke@gmail.com
- **Attachment:** An image named “receipt_mod.jpg”
- **Message:** Confirms payment and asks the recipient to acknowledge the receipt

LAYER 1: Initial Triage and Header Analysis

Objective: Analyze email headers to verify authenticity and detect signs of spoofing or suspicious origin.

Key Findings:

- **SPF (Sender Policy Framework):** Pass — The sending IP 209.85.220.41 is authorized to send on behalf of gmail.com.

Original Message

Message ID	<68f76f68.050a0220.b4bcf.8424@mx.google.com>
Created at:	Tue, Oct 21, 2025 at 12:32 PM (Delivered after 2 seconds)
From:	Avocado attorney <avocadoattorney1@gmail.com>
To:	onyedikapaulashuke@gmail.com
Subject:	PAYMENT CONFIRMATION!!!!
SPF:	PASS with IP 209.85.220.41 Learn more
DKIM:	'PASS' with domain gmail.com Learn more
DMARC:	'PASS' Learn more

[Download Original](#) [Copy to clipboard](#)

DKIM (Domain-keys Identified Mail): Pass — Email signatures are valid for gmail.com.

Original Message

Message ID	<68f76f68.050a0220.b4bcf.8424@mx.google.com>
Created at:	Tue, Oct 21, 2025 at 12:32 PM (Delivered after 2 seconds)
From:	Avocado attorney <avocadoattorney1@gmail.com>
To:	onyedikapaulashuke@gmail.com
Subject:	PAYMENT CONFIRMATION!!!!
SPF:	PASS with IP 209.85.220.41 Learn more
DKIM:	'PASS' with domain gmail.com Learn more
DMARC:	'PASS' Learn more

[Download Original](#)

[Copy to clipboard](#)

DMARC: Pass — Domain-based message authentication, reporting, and conformance policy passed.

Original Message

Message ID	<68f76f68.050a0220.b4bcf.8424@mx.google.com>
Created at:	Tue, Oct 21, 2025 at 12:32 PM (Delivered after 2 seconds)
From:	Avocado attorney <avocadoattorney1@gmail.com>
To:	onyedikapaulashuke@gmail.com
Subject:	PAYMENT CONFIRMATION!!!!
SPF:	PASS with IP 209.85.220.41 Learn more
DKIM:	'PASS' with domain gmail.com Learn more
DMARC:	'PASS' Learn more

[Download Original](#)

[Copy to clipboard](#)

Return-Path: avocadoattorney1@gmail.com (unrecognized, generic-looking).

Received path: The email originated from a Google mail server (mail-sor-e41.Google.com), IP 209.85.220.41, a legitimate Gmail IP

Message-ID: Looks standard, no obvious signs of forgery.

Timestamp: Email sent early morning (5:32AM PDT), unusual timing but not conclusive

Header Analysis Summary:

No direct evidence of spoofing based on SPF, DKIM, and DMARC.

However, this does not guarantee legitimacy — attackers can use compromised or newly created legitimate Gmail accounts.

The sender email and name do not match any official or known company, raising suspicion.

LAYER 2: Body and Content Analysis

Objective: Analyze the email content, language, attachment, and formatting for suspicious elements.

Observations:

Generic Greeting: "Dear Subscriber" instead of addressing by name.

Urgency & Request: Asks to "acknowledge receipt" to confirm payment — a common phishing tactic.

Vague Details: No clear details about the payment or company e.g (no company logo, design not paypal's design).

Attachment: Named receipt_mod.jpg (possibly modified), but the content is not clearly a legitimate receipt.

Base64 Encoded Text: The body text is encoded in Base64, which is unusual for normal emails.

Attachment Missing: The base64 section for the attachment is empty — possibly incomplete or purposely removed.

Formatting: Broken MIME boundary for attachment, indicating poor construction or tampering.

Content Analysis Summary:

Email tries to manipulate the recipient into opening the attachment or replying.

Poor grammar and vague information are classic indicators of phishing. Attachment might contain malware or be a lure to download malicious content.

Base64 encoding in the body is abnormal and often used to obfuscate content.

LAYER 3: Infrastructure Investigation

Objective: Investigate sender domain, IP reputation, and hosting infrastructure.

Infrastructure Notes:

Sender Domain: gmail.com — a common public email domain.

IP Address: 209.85.220.41 belongs to Google's Gmail SMTP servers — no negative reputation.

Domain Reputation: Gmail is generally trustworthy but can be abused.

Sender Account: avocadoattorney1@gmail.com — suspicious name, not an official domain.

No external links or domains referenced in the email body or headers.

Infrastructure Summary:

Attackers often use **free public email accounts** to send phishing emails.

This account name looks **random and unrelated** to any official company. Infrastructure itself is clean, but this is a common tactic to **bypass** detection by using reputable email providers.

LAYER 4: IOCs Extraction & Reporting

Indicators of Compromise (IOCs) identified from the email:

Type	Indicator	Description / Notes
Email Artifact	suspicious email.eml	Original phishing or dropper email file
Attachment	receipt_mod.jpg	JPEG file containing hidden Python payload
Hidden Payload	exec.py	Extracted Python file, likely stage-1 or decoy script
Obfuscated String	cmVwb3J0X2xvZy50eHQ=	Base64 for report_log.txt — used as log filename
File Output	.localdata/ (hidden folder)	Script writes output to a hidden directory
Created Files	report_log.txt and marker.txt	Log and marker files created during execution
Encryption Method (Steghide)	rijndael-128, cbc	AES encryption variant used for data concealment
Suspicious Behavior	os.makedirs(), hidden write ops, base64 decoding	Typical sandbox-evasion or staging behavior
System Call	os.getpid()	Captures process ID — common for anti-analysis markers
Timestamp Manipulation	sleep(1)	Artificial delay, possibly for sandbox timing evasion

Attacker' s Tactics, Techniques, and Procedures (TTPs):

Category	Description
Tactic: Phishing	Using social engineering to trick recipient into opening attachment or replying.
Technique: Email Spoofing	Using a free Gmail account that appears legitimate but is unrelated to company.
Procedure: Attachment Delivery	Sending an image file with a misleading name "receipt" to lure trust.
Obfuscation: Base64 encoding	Encoding email content to evade simple keyword detection by email filters.
Psychological Manipulation: Urgency and authority by claiming payment confirmation.	

Conclusion:

The email **cannot be trusted** despite passing SPF/DKIM checks because it originates from a suspicious free Gmail account and contains many phishing indicators.

The attachment could contain malware or lead to further compromise.

Staff should **not open the attachment** or reply.

This email should be **blocked and reported** as phishing.

Recommend training staff to recognize similar phishing attempts.

Further screenshot proofs:

Email body highlighting vague language and base64 encoding.

```
MIME-Version: 1.0
Content-Type: text/plain; charset="utf-8"
Content-Transfer-Encoding: base64

CkRlYXlU3Vic2NyaWJlciwKClRoaxMgaXMgdG8gaW5mb3JtIHlvdSB0aGF0IG91ciBmaX
JtIGhh
cyBjb25maXJtZWQgdGh1IHhew1lbnQgdG8gew91ciBhY2NvdW50LgpLaW5kbHkgYWNRbm
93bGVk
Z2UgdGh1IHJlY2VpcHQgdG8gY29uZmlybSBwYXltZW50IG9uIHlvdXlZw5kLgoKVGHhbm
sgew91
LgoK
-----1996564015038197965==
Content-Type: application/
MIME-Version: 1.0
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="receipt_mod.jpg"
```

Attachment information showing suspicious file name and missing content.

```
sgew91
LgoK
-----1996564015038197965==
Content-Type: application/
MIME-Version: 1.0
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="receipt_mod.jpg"
-----1996564015038197965---
```



```
(kali㉿kali)-[~/Desktop]
$ nano 'suspicious_email.eml'

(kali㉿kali)-[~/Desktop]
$ ripmime -i "suspicious_email.eml" -d extracted

(kali㉿kali)-[~/Desktop]
$ la -ls extracted/
total 128
124 -rw----- 1 kali kali 126599 Oct 27 04:05 receipt_mod.jpg
 0 -rw-rw-r-- 1 kali kali    0 Oct 27 04:05 textfile0
 4 -rw----- 1 kali kali   174 Oct 27 04:05 textfile1
```

Malware Analysis: Analysis showing embedded python file possibly a payload

```
(kali㉿kali)-[~/Desktop/extracted]
└─$ steghide info receipt_mod.jpg
"receipt_mod.jpg":
  format: jpeg
  capacity: 5.2 KB
Try to get information about embedded data ? (y/n) y
Enter passphrase:
  embedded file "exec.py":
    size: 789.0 Byte
    encrypted: rijndael-128, cbc
    compressed: yes

(kali㉿kali)-[~/Desktop/extracted]
└─$ steghide extract -sf receipt_mod.jpg
Enter passphrase:
wrote extracted data to "exec.py".

(kali㉿kali)-[~/Desktop/extracted]
└─$ nano exec.py
```



```
File Actions Edit View Help
GNU nano 8.4
import sleep
import base64
import os
import sys
from time
# encoded filename (minor obfuscation)
enc = b'cmVwb3J0X2xvZy50eHQ=' # base64 for 'report_log.txt'
fname = base64.b64decode(enc).decode()

def simulate_activity(path):
    os.makedirs(path, exist_ok=True)
    p = os.path.join(path, fname)
    with open(p, 'a') as f:
        f.write("SIMULATED RUN - PID: {}\n".format(os.getpid()))
    # create a marker file and timestamp
    with open(os.path.join(path, 'marker.txt'), 'w') as m:
        m.write("marker created\n")
    # small "sleep" to show process runtime in dynamic analysis
    sleep(1)

def main():
    # write into a "hidden" folder inside current dir
    hidden = os.path.join(os.getcwd(), '.localdata')
    simulate_activity(hidden)
    print("Simulation complete. Check {}".format(hidden))

if __name__ == "__main__":
    main()
```